COMPTIA SECURITY+ SY0-701 | DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.2 · Intrusion Prevention

Mestre CyberSec · **Lesson 3.2 — Intrusion Prevention** (5:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** IPS: fica INLINE (no caminho) e BLOQUEIA o ataque. Fail-open: se o IPS falha, deixa passar (disponibilidade > segura); fail-close (bloqueia tudo — mais seguro). IDS passivo + inline = 2 modos: detecta e alerta vs barra.

💡 Key Exam Highlights & Critical Concepts

- IPS inline BLOQUEIA; IDS passivo SÓ detecta/alerta
- Fail-open = disponibilidade; fail-close = segurança
- Configuração errada de IPS = bloquear negócio real (false positive)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'blocks attacks inline' = IPS
- 'if the device fails it allows traffic'=fail-open

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.2 — Intrusion Prevention)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Intrusion Prevention System (IPS)

A security control placed inline in the network path that actively inspects traffic and automatically blocks malicious packets in real time, without human intervention.

⚠️ ***Exam Trap:*** *If the question says 'blocks attacks automatically' or 'inline and stops traffic', the answer is IPS — never IDS. IDS only alerts; IPS blocks.*

• Intrusion Detection System (IDS)

A passive monitoring system that analyzes a copy of network traffic (via port mirror/TAP) to detect suspicious activity and generate alerts, but does not stop the traffic.

⚠️ ***Exam Trap:*** *'Detects and alerts but does not block' = IDS. If traffic would be stopped by the device, it is an IPS, not an IDS.*

• Fail-open (N/A)

An IPS failure mode where, if the device loses power or crashes, traffic is allowed to pass through unrestricted, prioritizing availability over security.

⚠️ ***Exam Trap:*** *Trigger phrase: 'if the device fails it allows traffic to pass.' This is the correct choice when business availability outweighs the risk of an outage.*

• Fail-closed (N/A)

An IPS failure mode where, if the device fails, all traffic is blocked, prioritizing security and integrity over availability.

⚠️ ***Exam Trap:*** *Trigger phrase: 'if the device fails it blocks all traffic.' Choose this when the network must never pass uninspected packets, even at the cost of downtime.*

• Inline deployment (N/A)

A network placement where the security device sits directly in the traffic flow between source and destination, forcing all packets to pass through it.

⚠️ ***Exam Trap:*** *Only inline devices can BLOCK traffic. Passive/out-of-band devices can only DETECT. The exam tests this distinction constantly.*

• Passive monitoring (N/A)

A deployment model where the sensor receives a copy of traffic (via SPAN port or network TAP) and analyzes it without being in the data path, so it cannot block packets.

⚠️ ***Exam Trap:*** *Passive + alerts = IDS. The exam often uses 'passive' as a synonym for IDS-style monitoring; do not confuse it with inline IPS.*

• False positive (FP)

An alert triggered by legitimate, non-malicious traffic that the IPS/IDS incorrectly identifies as an attack, often causing real business traffic to be blocked.

⚠️ ***Exam Trap:*** *Tuning questions on the exam: a misconfigured IPS that blocks legitimate transactions is a false positive problem — adjust signatures, do not disable the device.*

• Network-based IPS (NIPS)

An IPS appliance deployed at strategic network chokepoints (e.g., between firewall and core switch) to inspect and block malicious traffic for entire segments.

⚠️ ***Exam Trap:*** *Compare with HIPS (host-based). On the exam, 'inline at the perimeter blocking attacks' = NIPS; 'agent on a single server' = HIPS.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 NIDS vs. NIPS: Passive Alarm vs. Active Inline Bouncer

🏠 **Real-World Analogy:** Think of building security: A NIDS (Detection) is a closed-circuit wall camera linked to an audible siren. When it records an intruder picking the lock, it sounds a horn and logs an alert, but possesses no physical hands to block the thief. A NIPS (Prevention) is an armed physical bouncer positioned squarely inside the doorway threshold: the moment someone brandishes a weapon, the bouncer tackles them instantly and slams the steel door shut.

🔍 **Root Cause & Background:** NIDS operates out-of-band analyzing traffic mirrors; it causes zero line latency but cannot actively drop an in-flight exploit. NIPS sits directly inline in the data path, dropping malicious frames in real-time, but adds microsecond processing latency and introduces single points of network failure.

🛡️ **GRC Auditor Perspective:** Verify that inline NIPS hardware includes optical or copper bypass switches (fail-open mechanisms) to avert systemic network blackouts; audit tuning logs to confirm signature updates do not generate business-halting false drops.

⚠️ **How CompTIA Tests This:** Trigger: 'security device positioned inline with network traffic that actively drops malicious packets in real time'. Answer: NIPS. If 'monitors a mirrored copy of network traffic and sends alerts without stopping traffic' -> NIDS.

📌 Capture Topologies: In-Band (Inline) vs. Out-of-Band (TAP / Port Mirroring)

🏠 **Real-World Analogy:** In-band (Inline) is placing a full-height turnstile directly inside a narrow hallway: every individual must step into it and wait. Out-of-band via Network TAP or Port Mirroring (SPAN) is installing an overhead angled mirror projecting light beams into an observation booth: foot traffic sprints unimpeded down the hall while analysts review the mirrored reflection.

🔍 **Root Cause & Background:** Inline deployments introduce latency and line degradation. When auditing multi-gigabit backbones where operational disruption is prohibited, engineers deploy passive optical TAPs or switch SPAN (Switched Port Analyzer) mirrors to deliver duplicate packet streams to out-of-band sensors.

🛡️ **GRC Auditor Perspective:** Audit physical access and network cabling to SPAN switch monitor ports and fiber TAPs; ensure unauthorized sniffers cannot attach to monitoring feeds carrying raw unencrypted enterprise traffic.

⚠️ **How CompTIA Tests This:** Trigger: 'switch feature configured to send a duplicate copy of all traffic on port 1 to an analysis device connected to port 2'. Answer: Port Mirroring / SPAN. If dedicated physical passive fiber-splitter hardware -> Network TAP.

📌 Detection Engines: Signature-based vs. Heuristic vs. Behavioral (Anomaly-based)

🏠 **Real-World Analogy:** Signature-based detection is a passport control agent comparing faces against a printed catalog of wanted fugitives: zero false matches, but completely blind to new fugitives not yet photographed. Heuristic detection is an agent stopping travelers wearing ski masks and oversized heavy winter parkas in tropical summer (rules-based suspicion based on characteristic traits). Behavioral (Anomaly-based) detection tracks established baseline habits: if a clerk who logs 50 MB daily suddenly tries uploading 80 GB of database records to a foreign server at 3:00 AM, it triggers an immediate lockdown.

🔍 **Root Cause & Background:** Polymorphic malware and zero-day vulnerabilities possess zero historical hashes or static byte strings. Behavioral engines establish statistical baseline activity models, allowing detection of uncataloged attacks when deviant spikes emerge.

🛡️ **GRC Auditor Perspective:** Verify automated hourly/daily signature subscription updates; audit behavioral anomaly baseline recalibration procedures to prevent alert fatigue triggered by baseline drift.

⚠️ **How CompTIA Tests This:** Trigger: 'engine detects zero-day attacks by establishing a baseline of normal network activity and alerting on statistically significant deviations'. Answer: Behavioral / Anomaly-based Detection.

📌 Classification Errors: False Positives vs. False Negatives

🏠 **Real-World Analogy:** A False Positive is an office smoke detector shrieking at deafening volume because someone lightly browned toast: zero real hazard, but massive interruption and annoyed staff. A False Negative is a raging electrical fire consuming the next room while the detector stays dead silent: a lethal danger goes completely undetected, yielding catastrophic destruction.

🔍 **Root Cause & Background:** Over-tuned sensitivity creates operational Alert Fatigue from false positives, causing analysts to ignore notifications. Under-tuned permissive engines produce dangerous false negatives, permitting active intrusion.

🛡️ **GRC Auditor Perspective:** Audit SOC performance metrics (MTTR, false-positive ratios, alert fatigue indices); ensure signature suppressions and false-positive exception whitelists undergo formal change management approval.

⚠️ **How CompTIA Tests This:** Trigger: 'security sensor flags legitimate administrative traffic as a malicious SQL injection attack'. Answer: False Positive. If 'malicious attack bypassed the sensor without triggering any alert' -> False Negative.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Network appliance installed directly inline that actively drops offending packets in real-time before delivery	**NIPS (Network Intrusion Prevention System)**
Passive out-of-band appliance monitoring mirrored packet feeds to alert administrators without dropping connections	**NIDS (Network Intrusion Detection System)**
Switch feature mirroring packets traversing a specified interface and duplicating them to a sensor analysis port	**Port Mirroring / SPAN**
Inspection methodology matching byte strings against static databases of cataloged threat patterns	**Signature-based Detection**
Engine constructing statistical baselines of acceptable behavior and triggering alerts upon significant anomalies	**Behavioral / Anomaly-based Detection**
Benign enterprise user traffic is erroneously classified and dropped as a malicious cyber attack	**False Positive**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company wants to automatically stop known exploit attempts targeting its public web servers before the packets reach the servers. Which deployment best meets this requirement?

A) Network-based IDS connected to a SPAN port

B) Network-based IPS deployed inline with prevention rules

C) Host-based IDS configured in detect-only mode

D) SIEM log correlation with email alerts

QUESTION 2 · EXAM SCENARIO

A security team already uses an IDS on a mirror port and receives alerts, but the CISO now wants malicious traffic to be stopped before it reaches the internal servers while keeping detection visibility. What should the team implement?

A) An additional passive IDS sensor on another SPAN port

B) A network-based IPS in inline mode with prevention signatures enabled

C) A honeypot placed in the DMZ

D) A NetFlow collector configured for anomaly reporting

QUESTION 3 · EXAM SCENARIO

A hospital deploys an inline IPS to protect its clinical network. If the IPS appliance fails, life-critical applications must remain available even though inspection will be temporarily unavailable. Which failure mode should be configured?

A) Fail-open

B) Fail-closed

C) Passive monitoring

D) Signature-only detection

QUESTION 4 · EXAM SCENARIO

A government agency requires that no uninspected traffic be allowed onto its classified network. Even if the inline IPS fails, traffic must be blocked rather than bypassing inspection. Which mode should be configured?

A) Fail-open

B) Fail-closed

C) Promiscuous mode

D) Port mirroring

QUESTION 5 · EXAM SCENARIO

After an inline IPS is deployed, users report that a payroll application stops working. IPS logs show a signature was triggered by a normal database query from the application. What should the administrator do first to restore service while maintaining protection?

A) Validate the event as a false positive and tune or create a targeted exception for that signature

B) Change the IPS failure mode to fail-closed

C) Move the IPS to a SPAN port without changing signatures

D) Disable all signatures related to database traffic permanently

QUESTION 6 · EXAM SCENARIO

A security analyst needs to monitor network traffic for suspicious activity but must not affect traffic flow or block any packets. Which solution should be used?

A) A network-based IDS deployed passively on a SPAN port

B) A network-based IPS deployed inline with drop rules

C) A fail-closed IPS on the core switch

D) A web application firewall in blocking mode

QUESTION 7 · EXAM SCENARIO

An enterprise wants to prevent outbound malware command-and-control traffic from leaving its network. The security team must stop the traffic before it reaches the internet. Where should a network-based IPS be deployed?

A) Inline on the egress path between the internal network and the internet

B) Passively on a SPAN port that mirrors internal traffic only

C) Only on endpoint devices as a host-based IDS

D) Connected only to the SIEM for event correlation

QUESTION 8 · EXAM SCENARIO

An inline NIPS rule matches a malicious packet, and the configured action for that signature is drop. What is the expected result?

A) The packet is blocked and an alert is generated

B) The packet is allowed but copied to a monitoring port

C) The packet is forwarded after being encrypted

D) The packet is queued for analyst approval before delivery

QUESTION 9 · EXAM SCENARIO

A retail company runs an e-commerce site that must remain available even during rare IPS failures. The security team accepts the risk that traffic may be uninspected for a short time during such a failure. Which configuration aligns with this decision?

A) Fail-open

B) Fail-closed

C) Passive TAP with no blocking

D) Load balancing across web servers

QUESTION 10 · EXAM SCENARIO

A company wants to detect and block network worm traffic attempting to spread between VLANs before it propagates. Which solution best meets this requirement?

A) A network-based IPS deployed inline at the VLAN boundary

B) A host-based IDS installed on each server

C) A passive network-based IDS connected to a SPAN port

D) An IPS configured only in fail-open mode

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Network-based IPS deployed inline with prevention rules

An IPS deployed inline can inspect traffic in the path and drop malicious packets before they reach the target. A passive IDS on a SPAN port can only detect and alert, and host-based detect-only mode does not block network exploits. SIEM correlation also does not prevent the attack in real time.

Question 2: Option B — A network-based IPS in inline mode with prevention signatures enabled

To block traffic inline, a network-based IPS must be placed in the path and configured with prevention actions. Additional passive IDS sensors, honeypots, and NetFlow analyzers provide detection or visibility but cannot drop the malicious traffic.

Question 3: Option A — Fail-open

Fail-open allows traffic to continue flowing if the IPS fails, prioritizing availability over security during the outage. Fail-closed would block traffic and could disrupt critical care. Passive monitoring and signature-only detection do not describe the failure behavior of an inline device.

Question 4: Option B — Fail-closed

Fail-closed blocks all traffic if the IPS fails, ensuring that no uninspected traffic enters the protected network. This prioritizes security over availability. Fail-open would allow traffic through, while promiscuous mode and port mirroring are passive monitoring concepts.

Question 5: Option A — Validate the event as a false positive and tune or create a targeted exception for that signature

The described event is a false positive because legitimate application traffic matched a signature. The correct first step is to validate it and then tune the signature or add a narrow exception so the legitimate traffic is allowed while malicious traffic remains blocked. Changing failure mode, moving to SPAN, or disabling all database signatures either does not solve the blocking issue or creates excessive risk.

Question 6: Option A — A network-based IDS deployed passively on a SPAN port

A passive network-based IDS receives copied traffic from a SPAN port and only detects and alerts, so it does not affect traffic flow and cannot block packets. An inline IPS, fail-closed IPS, or blocking WAF can interrupt traffic, which does not meet the non-disruptive requirement.

Question 7: Option A — Inline on the egress path between the internal network and the internet

To stop outbound malicious traffic, the IPS must be inline on the egress path so it can drop packets before they leave the network. Passive SPAN monitoring, host-based IDS, and SIEM-only correlation provide visibility or alerts but cannot block the outbound connection in real time.

Question 8: Option A — The packet is blocked and an alert is generated

In an inline NIPS, a drop action blocks the matching packet and normally logs or alerts on the event. Allowing or copying the packet would be detection-only behavior, encryption is unrelated, and inline IPS prevention does not wait for manual approval for each packet.

Question 9: Option A — Fail-open

Fail-open lets traffic bypass the IPS if it fails, preserving availability while temporarily reducing inspection. Fail-closed would block traffic and hurt availability. Passive TAP and load balancing do not define the IPS failure behavior or the accepted security tradeoff.

Question 10: Option A — A network-based IPS deployed inline at the VLAN boundary

An inline NIPS at the VLAN boundary can inspect and drop worm traffic before it spreads. Host-based IDS and passive IDS detect or alert but do not block inter-VLAN traffic inline. Fail-open only describes failure behavior and does not provide prevention.